

SecurityGroup101 — Vendor Inherent Risk Questionnaire (IRQ)

Administered BEFORE the full CAIQ assessment to determine the scope of due diligence required. Score determines assessment pathway.

NIST SP 800-161 Rev. 1 Upd. 1 SR-2, SR-9 · NIST SP 800-53 Rev. 5 RA-3 · NIST CSF 2.0 ID.RA-09 · July 2026 · Maxine Jones, GRC Analyst — mkj00015@mix.wvu.edu

Vendor Name	
Date Administered	
Administered By	

#	Domain	Question	Response	Points	Rationale — Framework Reference
1	Data	Is the vendor internet-accessible (reachable from outside SG101's network)?	Yes / No / N/A	3 pts	NIST SP 800-161 Rev. 1 Upd. 1 Sec. 2.4 — Internet exposure is a primary inherent risk factor in C-SCRM assessments.
2	Data	Will the vendor store, process, or transmit Protected Health Information (PHI)?	Yes / No / N/A	4 pts	HIPAA Security Rule 45 CFR §164.312. Triggers Business Associate Agreement requirement and maximum regulatory exposure.
3	Data	Will the vendor store, process, or transmit payment card data (PCI scope — PANs, CVVs, or cardholder data)?	Yes / No / N/A	4 pts	PCI DSS v4.0 Req 12.8 — Third-Party Service Provider requirements. Triggers written agreement and annual compliance confirmation.
4	Data	Will the vendor store, process, or transmit Personally Identifiable Information (PII)?	Yes / No / N/A	3 pts	GLBA Safeguards Rule §314.4(f). State privacy law obligations. Risk reflects sensitivity and volume of PII involved.
5	Data	Will the vendor handle SG101 Confidential data (financial records, proprietary business data)?	Yes / No / N/A	2 pts	GLBA Safeguards Rule — data handling and disposal controls required in vendor contracts for Confidential data.
6	Access	Will the vendor have administrative or privileged access to any SG101 production system?	Yes / No / N/A	4 pts	NIST SP 800-53 Rev. 5 AC-6, SA-9. Privileged access is the highest-risk access scenario. Single compromise can enable full environment access.
7	Access	Will the vendor have non-privileged direct access to SG101 production systems?	Yes / No / N/A	3 pts	NIST SP 800-161 Rev. 1 Upd. 1 — all third-party production access requires documented access controls and monitoring.
8	Access	Will the vendor integrate with SG101 systems via API or automated data feeds?	Yes / No / N/A	2 pts	CSA CCM v4.0 AIS-03. NIST SP 800-53 Rev. 5 SC-8. API integration creates persistent automated data pathways requiring ongoing monitoring.
9	Cloud	Is the vendor's service cloud-hosted (SaaS, PaaS, or IaaS)?	Yes / No / N/A	2 pts	NIST SP 800-161 Rev. 1 Upd. 1 Appendix C — cloud services introduce shared-responsibility model complexity and require additional assessment focus.

#	Domain	Question	Response	Points	Rationale — Framework Reference
10	Cloud	Does the vendor store or process SG101 data outside the United States?	Yes / No / N/A	3 pts	GLBA Safeguards Rule. Applicable state privacy laws. NIST SP 800-161 identifies geographic location as a key supply chain risk factor.
11	Supply Chain	Does the vendor engage subcontractors (fourth parties) who may access SG101 data or systems?	Yes / No / N/A	2 pts	NIST SP 800-161 Rev. 1 Upd. 1 Sec. 2.6 — sub-tier supplier risk. PCI DSS v4.0 Req 12.8.5 — TPSP subcontractor disclosure required.
12	Supply Chain	Is the vendor's service dependent on open-source components with known or unpatched vulnerabilities?	Yes / No / N/A	2 pts	EO 14028 (Improving the Nation's Cybersecurity). NIST SP 800-161 Rev. 1 Upd. 1 Appendix F — software supply chain security requirements.
13	Business	Would a compromise of this vendor prevent SG101 from delivering its core product or service?	Yes / No / N/A	3 pts	NIST SP 800-161 Rev. 1 Upd. 1 SR-9 Criticality Analysis — requires documented criticality rationale and prioritization for each vendor.
14	Business	Is this vendor the sole provider of this service (no readily available alternative)?	Yes / No / N/A	2 pts	NIST SP 800-161 Rev. 1 Upd. 1 — single-source dependencies amplify inherent risk and should be documented with contingency plans.
15	Compliance	Is this vendor subject to an independent compliance certification (SOC 2 Type II, ISO 27001, PCI DSS Level 1, FedRAMP)?	Yes / No / N/A	-1 pts (credit)	Risk credit — independent certification reduces inherent risk by demonstrating externally validated controls. Negative score applied as mitigation credit.
16	Compliance	Has this vendor experienced a publicly reported data breach or security incident within the past 24 months?	Yes / No / N/A	4 pts	NIST SP 800-161 Rev. 1 Upd. 1 Appendix E — incident history is a baseline risk factor in supply chain risk assessments.

SCORING KEY — Inherent Risk Rating and Assessment Pathway

Score Range	Rating	Assessment Pathway
0 – 10	LOW	Proceed to abbreviated questionnaire (36-question Scoring Rubric). Tier 3 or 4 assessment pathway.
11 – 21	MODERATE	Proceed to standard 36-question scoring rubric. Tier 2 assessment pathway.
22 – 32	HIGH	Full CAIQ v4 assessment required. Tier 1 or 2 pathway with enhanced contract requirements. CISO notification.
33+	CRITICAL	Full CAIQ v4 plus current SOC 2 Type II report required. CISO must approve onboarding. Tier 1 pathway only.

Framework: NIST SP 800-161 Rev. 1 Upd. 1 (Nov. 2024) SR-2, SR-9 · NIST SP 800-53 Rev. 5 RA-3 · NIST CSF 2.0 ID.RA-09 · PCI DSS v4.0 Req 12.8 · GLBA Safeguards Rule §314.4(f) · Max score (all Yes, no credits): 43 points · github.com/Mkjones10/securitygroup101-enterprise-grc-program